

[별표1]

정보화사업 관련 정보보안사항

I. (보안성 검토) ① 사업부서의 장은 정보화사업 계획 수립 시 본청 정보보안담당관에게 보안성 검토를 의뢰하여야 한다.

② 사업부서의 장은 보안성검토를 의뢰할 경우에는 다음 각 호의 서류를 제출하여야 한다.

1. 사업계획서(사업 목적 및 추진계획 포함)
2. 제안요청서(RFP)
3. 정보통신망 구성도(필요시 IP주소체계 추가)
4. 자체 보안대책

③ 제2항 제4호에 따른 자체보안대책 마련사항에는 다음 각 호를 포함하여야 한다.

1. 보안관리 수행체계(조직, 인원) 등 관리적 보안대책
2. 정보시스템 설치장소에 대한 보안관리방안 등 물리적 보안대책
3. 국가정보원장이 개발하거나 안정성을 확인한 검증필 암호모듈
· 정보보호시스템 도입·운용 계획
4. 국가기관간 망 연동 시 해당 기관 간 보안관리 협의사항
5. 서버, 단말기, 휴대용기억매체, 네트워크 등 정보통신망의 요소별 기술적 보안대책
6. 재난복구 계획 또는 상시 운용계획
7. 용역업체 작업장소에 대한 보안대책
8. 누출금지정보 보안관리 방안

④ 사업부서의 장은 보안성 검토 결과를 준수하여 정보화사업을 추진하여야 한다.

⑤ 사업부서의 장은 다음 각 호에 해당하는 정보화사업에 대하여는 보안성 검토 절차의 이행을 생략할 수 있다. 이 경우 사업부

서의 장은 자체 보안대책을 수립·시행하여야 한다.

1. 정보화사업에 해당하지 아니하는 단순 장비·물품 도입
2. 1항에 따른 보안성 검토를 거쳐 완료한 정보화사업에 대하여 정보통신망 구성을 변경하지 아니하는 범위 내에서 다음 각 목의 사항을 포함한 후속운영·유지관리·컨설팅(단일 회선의 이중화는 본 호를 적용함에 있어 정보통신망 구성의 변경이 아닌 것으로 본다.)

가. 서버·스토리지·네트워크장비 등 장비 노후화로 인한 단순 장비 교체

나. 전화기·무선기·CCTV 등 통신·영상기기의 노후화로 인한 단순 장비 교체

다. 기존 운용하던 정보보호시스템을 동일한 보안 기능을 보유한 다른 정보보호시스템으로 교체

3. 다년도에 걸쳐 계속되는 사업으로서 사업 착수 당시 보안성 검토를 완료한 후 사업 내용의 변동 없이 계속 추진하는 운영·유지 사업

4. PC·프린터 및 상용 소프트웨어 등 단순 제품 교체

⑥ 사업부서의 장은 제5항 제2호부터 제4호까지에 해당하는 정보화사업을 수행할 경우 기존 보안성 검토 결과를 준수하여야 한다.

II. (개인정보 보호대책) 사업부서의 장은 정보화사업계획 수립 시 다음 각 호에 대한 개인정보 보호방안을 마련하여 사업계획에 포함하여야 한다. 다만, 해당사항이 전혀 없거나 개인정보 노출 위험성이 거의 없는 경우는 제외한다.

1. 개인정보파일을 구축·운용하거나 기존 시스템을 변경 또는 연계하려는 경우 등 「개인정보보호법 시행령」 제35조의 개인정보 영향평가 대상에 해당하는 경우, 개인정보영향평가 실시
2. 인터넷 대민서비스의 웹 서비스 개편, 신규 서비스 개발 시 서비스 운영 전 취약점 점검·모의해킹 실시 및 취약점 보완

3. 개인정보에 대한 입력·수정·삭제·열람 사항 및 조회자 인적사항 로그기록 관리
4. 인터넷 웹서비스를 운영할 경우 게시판 필터링, 키보드 해킹 방지 등 개인정보 노출 사전차단 시스템 도입
5. 개인정보 수록 DB에 대한 보안관리 (고유식별정보 암호화, DB 접근권한 제한 등)
6. 개인정보 송·수신 시 보안관리 (행정정보공동이용시스템 이용, 개인정보 암호화 등)
7. 개인정보 이용 시 기술적 보안 강화 (접근권한 차등 부여, 개인정보 취급자 접근권한을 공동인증서를 통한 인증 등)

III. (입찰시 보안관리) ① 중요외주용역사업은 착수단계부터 적정 등급의 비밀 또는 대외비로 분류하여 용역 의뢰하고 '대외주의', '요보안' 등 모호한 표현을 사용하지 말아야 한다.

- ② 입찰공고 시에 용역사업관련 기밀유지의무 및 위반 시 불이익 등의 내용을 사전 고지하여야 한다.
- ③ 제안서의 평가요소에 문서·시설·장비 등 보안관리계획에 대한 평가항목 및 배점기준을 마련하여야 한다.
- ④ 업체가 입찰제안서에 제시한 용역사업 전반에 대한 보안관리 계획이 타당한지를 검토하여 사업자 선정 시 이를 반영하여야 한다.
- ⑤ 웹호스팅 등 정보시스템을 위탁운영 시에는 해킹에 대비해 웹 방화벽 등 관련 보안시스템이 구비되어 있는지 여부와 단순 운영 이외 보안관리가 가능한지 여부를 심층 검토하여야 한다.

IV. (계약시 보안관리) ① 사업부서의 장은 용역사업 참여인원을 용역업체 임의로 교체 금지 및 신상변동사항 발생시 발주기관에 즉시 보고하도록 명시하여야 한다.

- ② 과업내용서에 자료 보안관리방법, 인원·장비·시설 등에 대한 보안점검·교육 등 보안관련 모든 사항을 상세히 기술하여야 한다.

③ 용역업체가 사업에 대한 하도급 계약을 체결할 경우 본사업 계약수준의 비밀유지 조항을 포함토록 조치하여야 한다.

V. (사업수행시 보안관리) ① 사업부서의 장은 용역사업 참여인원에 대해 보안서약서 징구 및 신원조사를 하여야 한다.

② 용역사업 참여인원에 대해 비밀유지 의무 준수 및 위반 시 처벌내용 등이 포함된 「정보보안규정」, 「국세청 정보보안 업무규정」, 「외부 용역사업 보안관리 세부지침」, 「개인정보보호법」의 주요 내용 등에 대한 보안교육을 용역사업 착수 시점(착수 1월 이내) 및 착수 이후 월 1회 이상 주기적으로 실시하고 전자적 방법으로 기록관리 하여야 한다.

③ 네트워크 구성도·IP현황, 개인정보 등 용역업체에 제공하는 비공개자료는 "자료관리대장"을 작성하여 인계자(사업담당자)와 인수자(용역업체 관리책임자)가 직접 서명한 후 인계·인수하여야 한다.

④ 용역사업 관련자료 및 사업과정에서 생산된 모든 산출물은 사업부서에서 지정한 파일서버 또는 PC에 저장·관리하여야 한다.

⑤ 용역사업 관련자료는 인터넷 웹하드 등 인터넷 자료공유사이트 및 개인메일함에 저장을 금지하여야 한다.

⑥ 용역사업 수행으로 생산되는 산출물 및 기록은 인가하지 않은 비인가자에게 제공·대여·열람을 금지하여야 한다.

⑦ 용역사업 수행 장소는 시건장치와 통제가 가능한 공간을 제공하거나 협의를 통해 동 환경이 구축된 외부 사무실을 사용하여야 한다.

⑧ 용역업체 사무실 또는 용역업무를 수행하는 공간에 대한 보안 점검을 정기적으로 실시하여야 한다.

⑨ 용역참여 직원이 노트북 등 관련장비를 반출 또는 반입할 때 마다 악성코드 감염여부 및 자료무단 반출 여부를 확인하여야 한다.

⑩ 인가받지 않은 USB 등의 보조기억매체 사용을 금지하며 산출

물 저장을 위해 보조기억매체가 필요한 경우 사전승인 후 사용하도록 하여야 한다.

⑪ 사업참여 인원에 대한 사용자계정(ID)은 하나의 그룹으로 등록하고 계정별로 정보시스템 접근권한을 부여하고 해당 계정에 대한 작업이력을 확인하여야 한다.

⑫ 내부서버 및 네트워크장비에 대한 접근기록을 반기 1회 이상 점검하여 접근의 적정성 여부를 검토하고 점검 결과를 본청 정보보안담당관에게 제출하여야 한다.

⑬ 용역업체에서 개발 및 운영을 위해 사용하는 노트북, PC는 인터넷 연결을 금지하여야 한다.

VI. (사업완료시 보안관리) ① 사업완료 후 생산되는 최종산출물 등 용역사업 관련 자료 중 대외보안이 요구되는 자료는 대외비로 작성·관리하고 불필요한 자료는 삭제 및 세단 후 폐기하여야 한다.

② 용역업체에 제공한 모든 자료, 장비, 서류와 중간·최종산출물 등 용역과 관련된 모든 자료는 전량 회수하고 업체에 복사본 등 별도 보관을 금지하여야 한다.

③ 노트북·보조기억매체 등 전자적으로 기록된 자료는 「국세청 정보보안업무규정」에 따라 복구가 불가능하도록 완전 소거하여야 한다.

④ 용역사업 관련자료 회수 및 삭제조치 후 업체에게 복사본 등 용역사업 관련자료를 보유하고 있지 않다는 대표 명의 확인서를 받아야 한다.